

Change record — P2 identity lifecycle and access governance

Retroactive change record, written to the standard Halden uses for every change (feeds the change log and the P10 governance dashboard). In a small company the same person often proposes and approves; that separation is documented honestly rather than pretended.

Field	Value
Change ID	CHG-2026-002
Title	P2 — Identity lifecycle: JML automation from an HR source of truth, hybrid identity, MFA, Conditional Access, access reviews
Raised by	IT (Muhammad Ibrahim Akmal)
Approved by	Managing Director (<i>business owner of the fictional Halden; see note on the lab</i>)
Date raised	2026-10-02
Planned implementation	2026-10-02 onwards, phase by phase (Phase 0 → Phase 6)
Category / risk	Identity and access — High risk (account creation and removal, tenant-wide sign-in policy)
Affected services	Logon, file access, cloud sign-in (Microsoft 365), the HR-to-IT process
Affected systems	DC01, DC02, FS01 (Cloud Sync agent), the Microsoft 365 trial tenant, WS01 (test client)
Depends on	P1 (OU tree, AGDLP groups, FS01 shares, OU=Disabled)

1. Description of the change

Replace the manual, email-driven account process with:

- an automated joiner-mover-leaver pipeline driven by the HR source-of-truth export, keyed on `EmployeeID` , with a desired-state role model, dry-run mode, a mass-change circuit breaker, a protected-accounts list and an append-only audit log;
- an account-hygiene report covering stale, password-exempt, disabled-retained and privileged accounts, plus accounts with no HR record;
- hybrid identity (AD to Microsoft Entra ID via Cloud Sync, scoped so admin and service accounts are never synced);
- MFA for all users and blocking of legacy authentication through five Conditional Access policies (CA001–CA005), created in report-only and then enforced, with two monitored break-glass accounts;
- quarterly access reviews, produced per department, signed off by the department heads, with every action tracked to closure;
- a CISA ScubaGear baseline assessment before and after.

The engine runs as a delegated gMSA with rights over two OUs only — not as a Domain Administrator.

2. Reason for the change

HR emails IT when someone joins, moves or leaves — sometimes. New starters wait two to three days for access; movers keep their old department's access; leavers' accounts stay active for weeks; there is no MFA; and nobody can answer "who has access to payroll?" with evidence. Stolen credentials are the most common initial access vector in reported breaches, and offboarding gaps are among the most frequent access-audit findings. This change makes access follow the HR record automatically, proves every change in a log, and puts a second factor in front of every account.

3. Impact and risk

Area	Impact	Mitigation
Staff	MFA prompts on sign-in; a one-page guide and a helpdesk surge plan accompany the rollout	Comms plan (<code>p2-mfa-rollout-comms.md</code>), staged rollout, Temporary Access Pass for onboarding
Logon / cloud access	A wrong Conditional Access policy could lock everyone out of the tenant	Policies start in report-only; two break-glass accounts created first and excluded from every policy; staged enablement
On-premises accounts	A bad HR file could disable a large share of accounts in one run	Dry-run preview, circuit breaker that aborts over 10%, protected-accounts list, per-user group snapshots, append-only audit log
Access control	An automated remover could revoke an access nobody asked it to manage	The mover only removes role groups named in the role matrix; anything else is reported, not touched
Identity hygiene	Seeding deliberately bad accounts for the "before" report leaves test accounts behind	A named, prefixed test set removed by the same script with <code>-Rollback</code> , and removed before the project is called Done
Privilege	An automation that creates and disables accounts is itself a sensitive identity	Delegated gMSA over two OUs, verified with <code>dsac ls</code> ; never Domain Admin
Privacy	The review pack contains names, usernames and last logon	Internal working document; sanitized before anything is published; role-played signatures recorded as simulations

4. Implementation plan (phases)

Phase	Work	Snapshot	Verification
0	Design document, as-is/to-be process map, role matrix, SLAs	none (nothing changes)	Design reviewed against the plan
1	JML engine, gMSA delegation, audit log, task schedule	<code>snap-p2-ph1-before</code> on DC01	Dry run correct; idempotent second run; <code>dsac ls</code> shows only the two OUs delegated

Phase	Work	Snapshot	Verification
2	Stale/privileged hygiene report (with seeded test accounts)	snap-p2-ph2-before on DC01	Report generated; findings listed; test accounts removed at rollback
3	Hybrid identity, break-glass accounts, CA001-CA005, auth methods, ScubaGear	snap-p2-ph3-before on DC01	Cloud Sync in scope only; CA in report-only then on; MFA prompt seen; legacy client blocked
4	Access-review pack and action tracker	none (read-only export)	One sheet per department; removals processed; re-export shows closure
5	Six lifecycle scenarios, including the corrupted HR file	snap-p2-ph5-before on DC01	Each scenario's expected result recorded in the test log
6	README, KPI table, CV bullets, as-built document	none	Real numbers only; anything unmeasured stays "not measured"

5. Test plan (acceptance)

1. A new Sales hire in the HR file → account, role groups and home drive created, with an audit entry.
2. A Finance-to-Operations transfer → loses the Finance access, gains the Operations access, old groups gone, in one run.
 1. A leaver with the end date today → disabled, sessions revoked, groups captured, moved within 15 minutes.
 1. A corrupted HR file with half the rows marked leaver → the circuit breaker aborts, an alert is raised, and nothing is changed.
 1. A user signs in with a password only → challenged for MFA (CA001).
 2. A legacy mail client signs in → blocked (CA002) and visible in the sign-in logs.
 3. Re-run the engine with no HR changes → an empty plan (idempotent).

6. Backout plan

Each phase is snapshotted before it runs (`snap-p2-ph<N>-before`). Backout for an on-premises phase is to revert the snapshot and re-run the previous phase's idempotent scripts. The cloud controls are configuration, so backout is to set the Conditional Access policies back to report-only (or delete a policy) and re-enable SMS/voice if enrolment is blocked. Leaver changes have their own targeted backout: re-enable from `logs/leavers/<EmployeeID>.json` after correcting the HR record. Domain controllers are fixed forward where possible: reverting a DC snapshot can disturb replication, so it is a last resort and is recorded in `DECISIONS.md`.

7. Post-implementation review

To be completed when the last phase is verified: actual completion date, acceptance test results, anything that went wrong, and whether any phase overran. Results are recorded in `projects/p02-identity-lifecycle/README.md` with a source file for every number.

Note: this is a home-lab change record for a fictional company (Halden Distribution Ltd.). The technical content, scripts and test results are real; the business approval line represents the lab owner's decision, not a real customer sign-off. The 85-person HR file is synthetic.

Halden Distribution Ltd. — home-lab portfolio artifact (fictional company, real configurations). Generated from p2-change-record.md on 2026-10-02.